

Cloudflare

Cloudflare provides a web application firewall (WAF), domain name system (DNS), and content delivery network (CDN) for the following zones:

- `gitlab.com`
- `staging.gitlab.com`
- `gitlab.net`

-
- Cloudflare Statuspage
 - Run a traceroute from the Cloudflare network

On-Call Reference

False Positive Triage Process

Change Workflow

Dashboard authentication

Cloudflare dashboard authentication uses Okta SSO, once a `@gitlab.com` email is typed in, the password field will fade out and the `Log in` button will switch to `Log in with SSO`. From there you will be redirected to GitLab's Okta instance for authentication.

Roles along with IdP configuration is managed by Terraform in the `cloudflare` environment in `config-mgmt`.

Okta app membership is managed in the Google `okta-cloudflare-users` group.

Cloudflare Rulesets Overview

Cloudflare's Web Application Firewall (WAF) provides protection against various threats and attacks targeting web applications. The WAF uses different types of rules to identify and mitigate malicious traffic before it reaches the origin server.

Custom Rules

Custom rules can filter traffic based on various parameters, such as IP addresses, Countries or Regions, URI paths, Request Methods etc. These allow us to manage traffic in ways such as blocking traffic, or serving a challenge to prove the traffic is not a bot.

Rate Limit Rules

Rate limit rules control the number of requests a client can make within a specified time period. These are used to manage how much traffic we serve to various parts of the application.

Managed Rules

These are pre-configured rulesets developed and maintained by Cloudflare's security team. They provide protection against common vulnerabilities and attack vectors without requiring manual configuration.

Page Rules

Page rules trigger when a certain URL pattern is matched. We use these to manage requests to certain parts of the GitLab product. These page rules are managed via Terraform. For more information, see [How Page Rules work](#)

Where to make changes The three zones that use Cloudflare each have a dedicated `cloudflare-pagerules.tf` file in its Terraform environment.

- `gitlab.net`
- `gitlab.com`
- `staging.gitlab.com`

How to make changes The Cloudflare provider for Terraform will not adhere to the `priority` value set in a page rule's resource. All but the lowest priority rule will need a `depends_on` section to point to the rule just below it in priority. And the rule above it will need to be updated to depend on the new rule.

This forces Terraform to apply the rules in a specific order, preserving their priority.

How to create new WAF rules

WAF rules are managed via Terraform for many services across GitLab, in the WAF rules shared module, which is then extended on for GitLab.com in `config-mgmt`. If your rule should also be used by other GitLab services (like Dedicated), add it to the `cloudflare-waf-rules` module. For more information on where rules should be added, follow this flowchart.

See the Handbook page for information on how and where rules should be created.

WAF Rules Naming Convention

For readability Cloudflare WAF rules follow a simple naming convention:

- **Custom rules:** The rule description must start with LOG, ALLOWLIST, BLOCK, BYPASS, CHALLENGE or CUSTOMER BYPASS, followed by a brief description of the rule (or relevant incident number) (examples: BLOCK - Incident #123456, CHALLENGE - Captcha Loop Investigation). For BYPASS rules, the ruleset or product being bypassed must also be included (example: BYPASS (rate limit) - Incident #123456).
- **Rate Limit rules:** The rule description contains the parameters of the rule (requests/seconds/counter) and a brief description of the function (examples: Runner jobs request endpoint (2400/60s/token), gitlab-org/gitlab issue 500 (20/60s/IP)).

These names are enforced by OPA policies in both `config-mgmt` and the `cloudflare-waf-rules` module.

The Custom Rules and Rate Limit Rules for each environment are found in:

- `gitlab.net` (ops environment)
- `gitlab.com` (production environment)
- `staging.gitlab.com` (staging environment)

Rule ordering

In order to keep rules in order (which is important at evaluation time on a request), additional rules need to be defined with a numerical value, for example

```
additional_rules = {
  custom_waf_before_bypass = {
    "2001" = {
      action      = "block"
      expression  = "blahblah"
      description = "foobar"
      enabled     = true
    }
  }

  custom_waf_after_bypass = {
    "5000" = {
      action          = "skip"
      expression      = "wwwwww"
      description     = "weeeeeeeeeee"
      enabled         = true
      enable_logging  = true
    }
  }
}
```

This number is utilised in the `ref` field, which is used as a stable identifier for each rule, so the number picked must:

1. satisfy the validations
2. not clash with any numbers used in the `cloudflare-waf-rules` module

General Information

- Vendor Info
- Services Locations
- WAF Service Information

Domain Name System (DNS)

- For the zones listed above, Cloudflare is the DNS resolver.
- DNS in Terraform is used to manage Cloudflare DNS entries.